

NES555 — Lab 3: Scanning & Enumeration (Reconnaissance & Network Probing)

Course: NES555 — Ethical Hacking Lab

Version: 2025-10-21 (updated)

Lab environment: Kali Linux VM (attacker) — use only instructor-approved lab targets / local lab VMs.

Lab overview — background & purpose

Active scanning and probing let you build an accurate map of a network: which hosts exist, which ports are open, what services and versions run, and how hosts respond to crafted probes. This lab trains you to perform **responsible active reconnaissance** and to interpret sometimes noisy results. Tools covered:

- **Nmap / Zenmap** — host discovery, port/service scanning, NSE scripts, OS detection.
- **Masscan** — extremely fast TCP SYN discovery (lab-scoped only).
- **hping3** — packet crafting for ICMP/TCP/UDP probing and TTL/fragmentation tests.
- **netcat** — lightweight banner grabbing and service interaction.
- **enum4linux** — SMB/Windows service enumeration.

You will compare results across scanners, validate findings with low-level probes, and produce a concise findings table useful for triage.

Learning objectives

By the end of this lab you will be able to:

1. Differentiate when to use Nmap, Masscan, and hping3.
 2. Discover hosts and open ports with Nmap and Zenmap and interpret service/version info.
 3. Use Masscan safely in lab subnets for rapid discovery and map results to Nmap scans.
 4. Craft ICMP/TCP/UDP probes with hping3 to validate host responsiveness and detect filtering/IDS behavior.
 5. Use netcat for banner grabbing and enum4linux for SMB/Windows enumeration.
 6. Correlate scanner outputs and compile a prioritized findings table with mitigation suggestions.
-

Estimated time

90–120 minutes (2 hours recommended)

Prerequisites & setup

- Kali VM running, attached to the lab network.
- Tools installed (most are in default Kali). If missing:

```
sudo apt update
sudo apt install -y nmap zenmap masscan hping3 netcat enum4linux tcpdump
wireshark
```

- Create workspace:

```
mkdir -p ~/nes555/lab3 && cd ~/nes555/lab3
```

- Instructor-provided target(s): replace `TARGET_IP`, `TARGET_HOST`, `TARGET_NET` with assigned addresses (e.g., `192.168.56.101`, `192.168.56.0/24`).

Mandatory safety rule: Do **not** run Masscan or any aggressive scans against the Internet or unauthorised hosts. Limit Masscan to the lab subnet or VMs only.

Tools quick reference

- `nmap / zenmap` — host discovery, SYN/ACK, UDP, version detection, NSE scripts.
 - `masscan` — ultra-fast TCP SYN scanner (lab-limited).
 - `hping3` — craft ICMP/TCP/UDP probes (TTL, flags, fragmentation, rate).
 - `netcat (nc)` — banner grabbing, simple service checks.
 - `enum4linux` — SMB/Windows enumeration (shares, users, OS info).
 - `tcpdump / wireshark` — capture/inspect probe traffic for validation.
-

Deliverables (what to submit)

A single PDF `NES555_Lab3_<YourName>_<ID>.pdf` containing:

- Executive summary (2–3 lines).
- Commands used (copy/paste).
- Key outputs (Nmap `-oA` files, Masscan output snippet, hping3 summary, netcat/enum4linux excerpts).

- Concise findings table (Host/IP → Open ports & services → Source/tool → Confidence/notes).
- Short mitigation recommendations (3 bullets).

Grading emphasis: correct technique, interpretation, and correlation.

Tasks — step-by-step (background + commands + expected notes)

Replace `TARGET_IP`, `TARGET_NET`, `TARGET_HOST` with instructor-provided values.

Task 0 — Workspace & capture prep (5–10 min)

Background: Always prepare a capture to validate what your scanners are actually sending/receiving.

Commands

```
mkdir -p ~/nes555/lab3/outputs
cd ~/nes555/lab3/outputs

# Start tcpdump in background to capture on interface (adjust iface)
sudo tcpdump -i eth0 -w lab3_capture.pcap &
TCPDUMP_PID=$!

# (After lab) kill capture
# sudo kill $TCPDUMP_PID
```

Notes

- If using Wireshark, load `lab3_capture.pcap` to inspect packets later.
-

Task 1 — Quick host discovery (10–15 min)

Background: Confirm live hosts before port scans. Use both ping-based and ARP discovery.

Commands

```
# Nmap host discovery (ping scan)
sudo nmap -sn 192.168.56.0/24 -oN nmap_ping_sweep.txt
```

```
# ARP-based discovery (works even if ICMP blocked)
sudo nmap -PR 192.168.56.0/24 -oN nmap_arp_sweep.txt

# Optionally: fping (if installed)
fping -a -g 192.168.56.0/24 2>/dev/null | tee hosts_up.txt
```

Expected notes

- Hosts that respond to ICMP vs those only visible via ARP.
 - If many hosts filtered ICMP, document that in notes (affects scan strategy).
-

Task 2 — Nmap: TCP SYN scan + version detection + NSE (30–40 min)

Background: Nmap is the primary scanning tool for detailed discovery—use staged scans: narrow then full.

A — TCP SYN quick scan (common ports)

```
# Save all formats for later review
sudo nmap -Pn -sS -T4 -p 1-1024 TARGET_IP -oA nmap_quick_TARGET
```

B — Full port + service/version + default NSE scripts

```
sudo nmap -sS -sV -sC -p- -T4 TARGET_IP -oA nmap_sV_all_TARGET
```

C — Targeted UDP scan (select ports)

```
sudo nmap -sU -p 53,67,69,123,161 TARGET_IP -T3 -oN nmap_udp_TARGET.txt
```

D — Aggressive scan with OS detection & traceroute

```
sudo nmap -A -T4 TARGET_IP -oN nmap_A_TARGET.txt
```

Options explained

- `-sS` SYN scan; `-sV` service/version; `-sC` default scripts; `-p-` all tcp ports.
- `-Pn` skip ping (use if hosts block ICMP).
- `-A` enables OS detection, version detection, script scanning, traceroute.

Expected notes

- Open ports with service/version (record service confidence).
 - NSE script outputs of interest (ssl-cert, http-title, ftp-anon, smb-os-discovery).
 - OS fingerprint results and their confidence levels.
-

Task 3 — Zenmap: visual profiling & diffs (10–15 min)

Background: Zenmap helps visualize topology, saved profiles, and compare scans.

Steps

1. Launch:

```
zenmap
```

2. Set Target = `TARGET_IP`, Profile = `Intense scan` or custom command from Task 2.
3. Run scan; explore **Topology**, **Hosts**, **Ports/Services** tabs.
4. Save scan and use **Scan** → **Compare Results** to see differences in consecutive scans.

Notes

- Use Zenmap to quickly present results and to visually spot changes across scans.
-

Task 4 — Masscan: high-speed discovery (lab-scoped) (10–15 min)

Background: Masscan is optimized for speed using raw packets—dangerous outside lab. Use it only on instructor-controlled subnets/VMs.

Commands

```
# Very fast scan on lab subnet (rate must be low for lab network)
sudo masscan 192.168.56.0/24 -p1-65535 --rate 1000 -oL masscan_out.txt
```

```
# Limit to common ports
sudo masscan 192.168.56.0/24 -p80,443,22,21,3389 --rate 1000 -oL
masscan_common.txt
```

Post-process to feed nmap

```
# Extract IP:port lines to feed Nmap (example)
awk '/open/ {print $3":"$4}' masscan_out.txt | sed 's/:/ /g' | sort -u >
masscan_targets.txt
# Use Nmap on a subset
sudo nmap -sS -sV -T4 -iL masscan_targets.txt -oA nmap_from_masscan
```

Notes

- `--rate` controls packets/sec — lower values for shared lab networks.
 - Validate Masscan results with Nmap (Masscan finds open ports but not service details).
-

Task 5 — hping3: ICMP/TCP/UDP probing & behavior analysis (25–30 min)

Background: hping3 crafts custom packets. Use it to test filtering, TTL behavior, SYN/ACK responses, and measure response differences vs. Nmap.

A — ICMP ping (raw)

```
# ICMP echo
sudo hping3 -l -c 4 TARGET_IP

# ICMP with spoofed TTL or fragmentation (experiment)
sudo hping3 -l -c 4 -t 10 TARGET_IP
sudo hping3 -l -c 4 -f TARGET_IP # fragmentation flag (careful)
```

B — TCP SYN probes (target port)

```
# SYN to port 80
sudo hping3 -S -p 80 -c 3 TARGET_IP

# SYN with custom source port and rate
sudo hping3 -S -p 80 -s 55555 --fast TARGET_IP
```

C — TCP ACK/FIN/RST probes to test firewall behavior

```
sudo hping3 -A -p 80 -c 3 TARGET_IP # ACK probe
sudo hping3 -F -p 80 -c 3 TARGET_IP # FIN probe
```

D — UDP probes

```
sudo hping3 --udp -p 53 -c 3 TARGET_IP
```

E — Capture & analyze

```
# Tail capture while probing
sudo tcpdump -r lab3_capture.pcap -n 'host TARGET_IP and (tcp or icmp or
udp) '
# Or live capture filtered
sudo tcpdump -i eth0 host TARGET_IP and tcp -w hping_probe.pcap
```

Notes

- Compare hping3 responses against Nmap: e.g., Nmap shows port filtered if hping3 SYN gets no response.
- Use hping3 sparingly to avoid IDS/IPS triggers even in lab.

Task 6 — netcat & enum4linux: service verification (10–15 min)

Background: Use netcat to connect interactively to services and enum4linux for SMB/Windows enumeration.

A — netcat banner grab / interaction

```
# Simple TCP banner (HTTP)
nc TARGET_IP 80
# then type: HEAD / HTTP/1.0
# or use:
echo -e "HEAD / HTTP/1.0\r\nHost: TARGET_HOST\r\n\r\n" | nc TARGET_IP 80

# Telnet-like check (if Telnet open)
nc TARGET_IP 23
```

B — enum4linux (SMB enumeration)

```
# Basic smb info (replace with discovered SMB host IP)
enum4linux -a TARGET_IP > enum4linux_TARGET.txt
```

Expected notes

- netcat may reveal service banners (e.g., Apache, SMTP greeting).
- enum4linux outputs shares, users, OS details—useful for Windows-targeted tests.

Task 7 — Correlate outputs & prepare findings table (15–20 min)

Why: Different tools produce different views. Correlating increases confidence and prioritizes remediation.

Suggested workflow

1. Consolidate open ports & services from Nmap, Masscan, and netcat:
all_findings.csv with columns:
IP,Port,Service,Version,Tool(s),Confidence,Notes
2. Note discrepancies (e.g., Masscan finds port X open but Nmap reports filtered) and explain likely reasons (timing, firewall, rate limits).
3. Prioritize high-risk services (RDP, SMB, exposed admin panels) with short mitigation bullets.

Findings table example

IP	Port	Service	Tool(s)	Confidence	Notes
192.168.56.101	22	ssh	nmap,syn,netcat	High	Open, OpenSSH 7.2p2

IP	Port	Service	Tool(s)	Confidence	Notes
192.168.56.101	445	smb	masscan,nmap,enum4linux	Medium	SMBv1 possibly enabled; enum4linux reveals shares

Troubleshooting & instructor notes

- If Nmap shows many ports as “filtered”: try `-Pn` or use `hping3` probes to see if ICMP is blocked.
 - Masscan may require root and raw socket privileges; ensure `--rate` low to avoid network disruption.
 - UDP scans (`-sU`) can be slow and noisy—limit to likely ports.
 - Zenmap may run Nmap as non-root; some checks (OS detection) need root privileges—use CLI `sudo nmap` for full capability.
 - Use `tcpdump`/wireshark to inspect packets if scan outputs seem inconsistent.
-

Sample mitigation recommendations (include in report)

- Close/disable unnecessary services; restrict management services to admin VLANs and IPs only.
 - Enforce strong authentication and patch known vulnerable versions (update OpenSSH/Apache/Samba).
 - Disable legacy protocols (Telnet/SMBv1); monitor with IDS for scanning patterns.
 - Implement rate-limiting and sensor tuning to detect mass-scan behaviors.
-

Submission checklist

- `NES555_Lab3_<YourName>_<ID>.pdf` with: exec. summary, commands used, concise findings table, and mitigation paragraph.
 - Attach Nmap `-oA` outputs or include selected XML/text snippets.
 - Attach Masscan output snippet and any `tcpdump` pcap excerpts you analyzed.
-

Wrap-up questions (for lab report)

1. Where did Masscan and Nmap disagree? Explain why (timing, rate, raw vs. stateful).
2. What did `hping3` show about filtering behavior that Nmap didn't? Give one concrete example.

3. Based on your findings, what are the top three remediation actions for the scanned hosts?

If you want, I can:

- Produce a one-page printable student handout (concise tasks + command cheatsheet), or
- Generate an instructor answer key with sanitized sample outputs for grading. Which would you like?